CONTINGENCY PLANNING

WyIT - 1003

PURPOSE: To ensure agencies managing internal IT infrastructure can sustain available IT resources and information systems during a service disruption.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by WyIT - 3002 - Security Exception Request policy.

IV. PLAN DEVELOPMENT

A. Requirements

A contingency plan must be developed for all information system(s) containing the following:

- Identifies essential missions, business functions, and associated contingency requirements;
- Provides recovery objectives, restoration priorities, and metrics;

- Addresses contingency roles, responsibilities, and assigned individuals with contact information;
- Addresses maintaining essential missions and business functions despite an information system disruption, compromise, or failure;
- Addresses eventual, full information system restoration without deterioration of the security safeguards originally planned and implemented and
- Reviewed and approved by the CIO and information system's owner management annually

B. Agency Responsibilities

- Distribute copies of contingency plans to key contingency personnel, identified by name and/or by business role.
- Coordinate contingency planning activities with incident handling activities.
- Annually update the contingency plan to address changes to the business owner's mission, information system, or environment of operation and problems encountered during contingency plan implementation, execution, or testing.
- Communicate contingency plan changes to key contingency personnel identified by name and/or by business role.
- Protect the contingency plan from unauthorized disclosure and modification.

V. TRAINING

A. Provide contingency training to information system users consistent with assigned roles and responsibilities.
B. Ensure designated personnel receive biannual contingency training upon assuming a role or responsibility and when required by information system changes.

VI. TESTING

A. Testing Requirements

- Annually test the contingency plan for the information system, as determined by the mission-critical nature of the business system(s).
- Use strategic and tactical planning during testing to simulate a production information system to determine the effectiveness of the plan and the organizational readiness to execute the plan.

- Review the contingency plan test results and initiate corrective actions as needed.
- Coordinate contingency plan testing with organizational elements responsible for related plans; plans related to contingency plans for information systems include, for example, Business Continuity Plans, Disaster Recovery Plans, Continuity of Operations Plans, Crisis Communications Plans, Critical Infrastructure Plans, Cyber Incident Response Plans, and Occupant Emergency Plans.

VII. ALTERNATE SITES

A. Establish an alternative storage site with the following requirements:

- Necessary agreements to permit the storage and retrieval of information system backup information.
- Information security safeguards equivalent to the primary site.
- Separate from the primary storage site to reduce susceptibility to the same threats.
- Log of potential accessibility problems to the alternate storage site, in the event of an area-wide disruption or disaster, with an outline of explicit mitigation actions.

B. Establish an alternate processing site with the following requirements:

- Necessary agreements which:
  - Permit the transfer and resumption of the information system operations for essential missions/business functions consistent with recovery time and recovery point objectives when the primary processing capabilities are unavailable.
  - Provide priority-of-service provisions according to business objectives and availability requirements.
- List of equipment and supplies required to transfer and resume operations at the alternate processing site.
- Ensure contracts are in place to support delivery to the site within the agreed-upon period for transfer/resumption.
- Information security safeguards equivalent to that of the primary site.
- Separated from the primary processing site to reduce susceptibility to the same threats.

- Log of potential accessibility problems to the alternate storage site, in the event of an area-wide disruption or disaster, with an outline of explicit mitigation actions.

VIII. BACKUPS

A. Conduct required backups of information system(s) defined by the frequency consistent with recovery time and recovery point objectives. These should include:

- User-level information, and
- System-level information,

B. Information system documentation should:

- Include security-related documentation;
- Protect the confidentiality, integrity, and availability of backup information at storage locations.

C. Backup information should be tested to verify media reliability and information integrity.

IX. RECOVERY AND RECONSTITUTION

A. Provide for the recovery and reconstitution of the information system to a known state after a disruption, compromise, or failure.

B. Provide that the information system implements transaction recovery for systems that are transaction-based.

REFERENCES

- Wyoming §§ 40-21-101 — 40-21-119

- IRS Publication 1075, Safeguards for Protecting Federal Tax Returns and Return Information

- Health Insurance Portability and Accountability Act (HIPAA)

- Minimum Acceptable Risk Standards for Exchanges (MARS-E) 2.0 Framework
- Family Education Rights Privacy Act (FERPA)
- Payment Card Industry – Data Security Standards (PCI-DSS)
- Criminal Justice Information Services (CJIS)
- Children's Online Privacy Protection Act (COPPA)

SUPERSEDED POLICY: This policy does not supersede any previous, known policies.

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
June 2024	ETS Governance, Risk and Compliance	Public Comment Period	06/14/2024 - 06/28/2024	July 2024

REVISIONS		
LAST REVISION DATE	**LAST REVISED BY**	**LAST APPROVED BY**

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**